



AEGIS CYBERSECURITY

SECURITY OPERATIONS CENTER — THREAT INTELLIGENCE DIVISION

INCIDENT REPORT — PROJECT 6

SSH Brute Force Attack & Privilege Escalation Analysis

SIEM-Based Log Analysis | Threat Detection | Incident Response

⚠ CRITICAL INCIDENT — HOST COMPROMISED | BACKDOOR INSTALLED

INCIDENT REFERENCE

INC-2026-0621

DATE OF REPORT

June 21, 2026

ANALYST

SOC Analyst — Tier 2

TARGET HOSTNAME

debian-server

OPERATING SYSTEM

Linux Debian

CURRENT STATUS

● Compromised

1

Executive Summary

High-level overview of the security incident and its impact

On **June 21, 2026**, the Aegis Security Operations Center (SOC) detected and investigated a multi-stage cyberattack targeting the Linux production server **debian-server**. Analysis of **/var/log/auth.log** records confirmed a coordinated SSH brute-force attack originating from an external threat actor at IP address **203.0.113.5**, which resulted in a full system compromise.

The attacker successfully authenticated into a local system account (support) after executing over **80 rapid password-guessing attempts**. Following initial access, the attacker escalated privileges to **root** via unauthorized sudo commands and created a backdoor user account (backuser) to maintain persistent access. Additionally, a secondary slow-rate scan from an internal device (192.168.1.150) targeting the root account was also identified.



Critical Finding — Immediate Action Required

Account '**support**' was successfully compromised by external IP **203.0.113.5**. The attacker achieved root-level access and created a persistent backdoor account. The server should be isolated immediately pending full forensic investigation and re-imaging.

Key Metrics at a Glance



2

Scope & Log Sources

Artifacts collected and analysis scope

ARTIFACT	SOURCE LOCATION	ENTRIES	STATUS
SSH Authentication Log	/var/log/auth.log	244 lines	ANALYZED
Failed Login Events	Parsed from auth.log	92 events	SUSPICIOUS
Sudo Audit Records	Parsed from auth.log	20 events	HIGH RISK
Successful SSH Sessions	Parsed from auth.log	9 sessions	UNDER REVIEW

3

Incident Timeline & Attack Analysis

Chronological reconstruction of the attack phases

Phase 1 — Approx. 04:00 | IP: 192.168.1.150

Internal Low-Rate Brute Force (Reconnaissance)

An internal device at **192.168.1.150** began a slow, low-frequency scan targeting the root account via SSH. Attempts were spaced approximately 10 minutes apart — a classic indicator of a rate-limiting bypass technique to evade automated security alerts. A total of 12 failed authentication events were recorded from this source.

Phase 2 — Approx. 08:00 | IP: 203.0.113.5

External High-Velocity Brute Force Attack

An external IP address **203.0.113.5** initiated a rapid, automated credential-stuffing attack targeting 9 distinct system usernames including root, admin, support, mysql, oracle, and others. A total of **80 failed login attempts** were recorded in under 5 minutes — consistent with automated brute-force tooling.

Phase 3 — 00:06:20 | IP: 203.0.113.5 → Account: support

🔑 Account Compromise — Successful Authentication

The attacker successfully authenticated as the local account support from the attacking IP. The SSH daemon accepted the password and opened an interactive remote shell session.

```
/var/log/auth.log - Compromise Event

Jun 24 00:06:20 debian-server sshd[21213]: Accepted password for support from 203.0.113.5 port 55431 ssh2
Jun 24 00:06:20 debian-server systemd-logind: New session 42 of user support.
Jun 24 00:06:20 debian-server sshd[21213]: pam_unix(sshd:session): session opened for user support by (uid=0)
```

Phase 4 — 00:08:20 to 00:10:05 | Actor: support

💀 Privilege Escalation & Root Shell Acquisition

After gaining access, the attacker executed a series of unauthorized sudo commands. Two attempts to read /etc/shadow and to create a new user via useradd were blocked by sudo policy. However, on the third attempt, the attacker successfully launched a root bash shell using sudo /bin/bash:

```
/var/log/auth.log - Privilege Escalation

Jun 24 00:08:20 debian-server sudo: support : command not allowed ; COMMAND=/usr/bin/cat /etc/shadow
Jun 24 00:09:05 debian-server sudo: support : command not allowed ; COMMAND=/usr/bin/useradd -m backuser
Jun 24 00:10:05 debian-server sudo: support : TTY=pts/2 ; USER=root ; COMMAND=/bin/bash
Jun 24 00:10:05 debian-server sudo: pam_unix(sudo:session): session opened for user root by (uid=0)
```

Phase 5 — 00:15:05 | Actor: root (via support)

🔒 Persistence — Backdoor Account Created

Within the elevated root shell, the attacker created a new local account named backuser with UID 1003 and assigned it a home directory and interactive shell — establishing a hidden persistence mechanism for future unauthorized re-entry.

```
/var/log/auth.log — Backdoor Installation
```

```
Jun 24 00:15:05 debian-server useradd: new user: name=backuser, UID=1003, GID=1003,  
home=/home/backuser, shell=/bin/bash
```

4

Indicators of Compromise (IoCs)

Forensic artifacts isolated for SIEM alerting and firewall integration

IOC TYPE	OBSERVED VALUE	CONTEXT	RISK	ACTION
IP Address	203.0.113.5	External attacker — 80 failed SSH attempts + successful login	CRITICAL	Block at perimeter firewall
IP Address	192.168.1.150	Internal scanner — slow brute force against root (12 attempts)	MEDIUM	Isolate & investigate device
User Account	support	Account compromised via brute force from 203.0.113.5	CRITICAL	Disable, reset password, audit sessions
User Account	backuser	Backdoor persistence account created by attacker at 00:15:05	CRITICAL	Remove immediately: userdel -r backuser
Sudo Command	/bin/bash	Used by 'support' to spawn interactive root shell	CRITICAL	Remove from sudoers, audit sudoers file
Target Accounts	root, admin, mysql, oracle...	9 usernames targeted in automated credential stuffing run	MEDIUM	Enforce password policies for all accounts

5

Evidence Collection & SIEM Dashboard Visuals

Forensic screenshots captured during the log analysis investigation

EV-01

CLI Log Analyzer — Automated Security Parsing Output

scripts/log_analyzer.py

```
Administrator: Windows PowerShell
Windows PowerShell 5.1
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\WINDOWS\system32> cd C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project
PS C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project> python scripts/generate_logs.py
C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project\scripts\generate_logs.py:107: DeprecationWarning: Parsing dates involving a day of month without a year specified is ambiguous
and fails to parse leap day. The default behavior will change in Python 3.15
to either always raise an exception or to use a different default year (TBD).
to avoid trouble, add a specific year to the input & format.
See https://github.com/python/cpython/issues/70647.
  logs.sort(key=lambda x: datetime.strptime(x[:15], "%b %d %H:%M:%S"))
[*] Successfully generated 244 simulated log entries at C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project\collected_logs\auth_logs.txt
PS C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project> python scripts/log_analyzer.py
[*] Security analysis complete. Results written to C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project\analysis_results\suspicious_login_attempts.txt
[*] Exported raw log data to dashboard assets at C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project\dashboard\log_data.js
- Failed Logins: 92
- Successful Logins: 9
- Brute Force IPs Detected: 2
- Compromises Identified: 1
- Critical Sudo Events: 3
PS C:\Users\abdxl\geminiantigravity\scratch\Log-Analysis-Project>
```

Figure 1: Python log_analyzer.py execution showing: 92 failed SSH logins, 9 successful logins, 2 brute-force IP sources, 1 confirmed account compromise, and 3 critical sudo escalation events detected automatically.

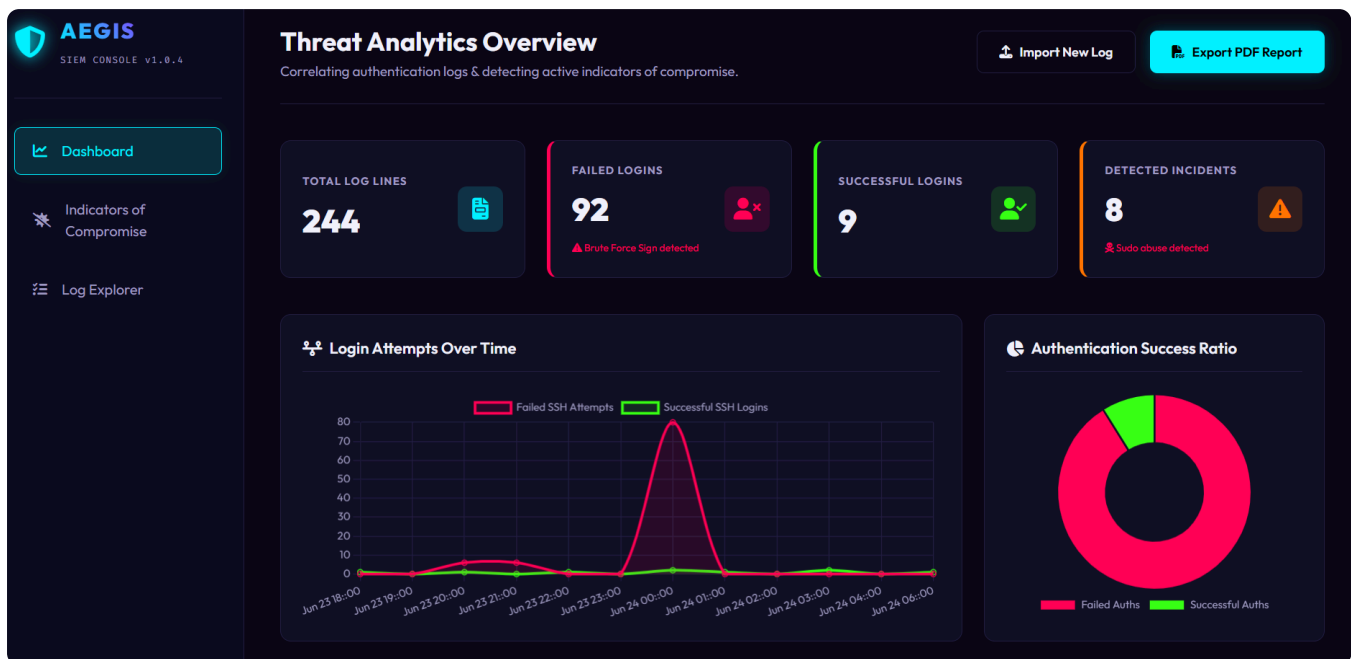
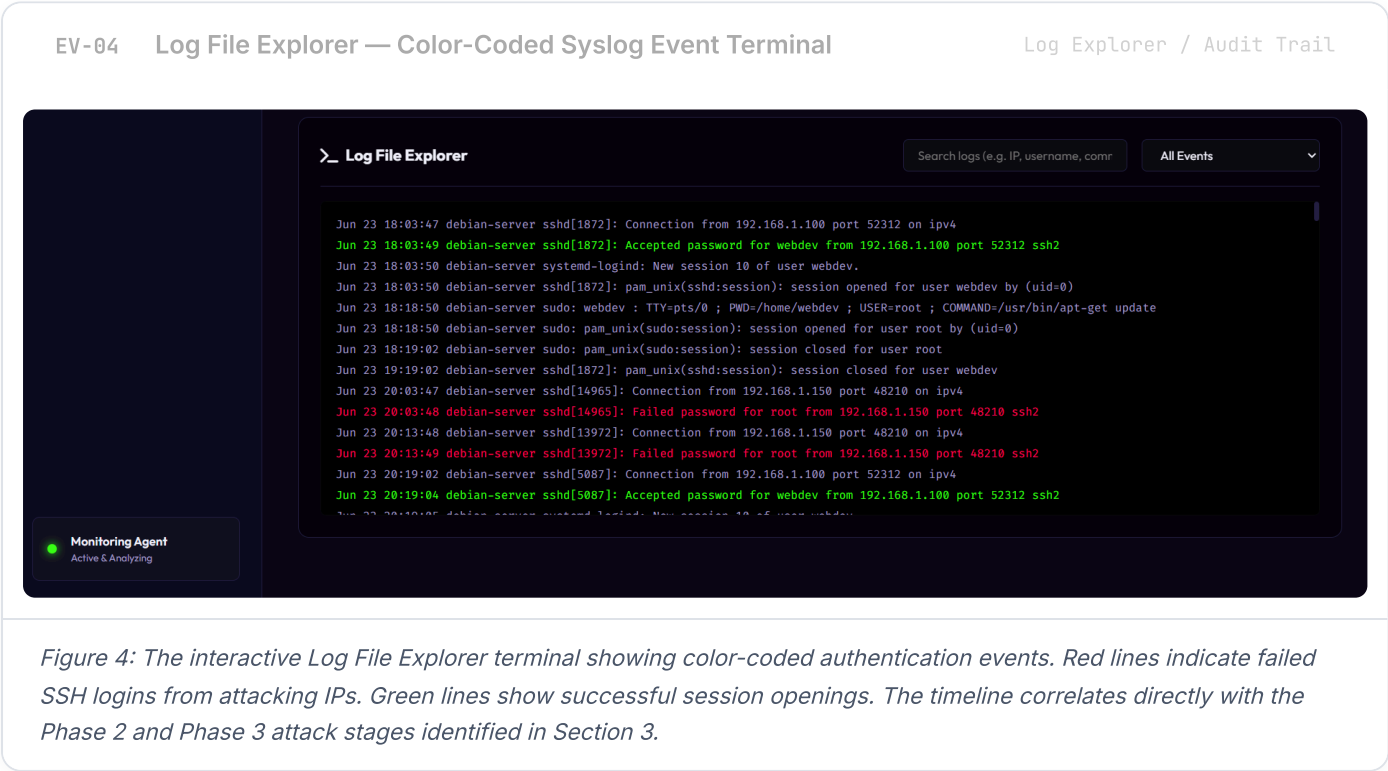
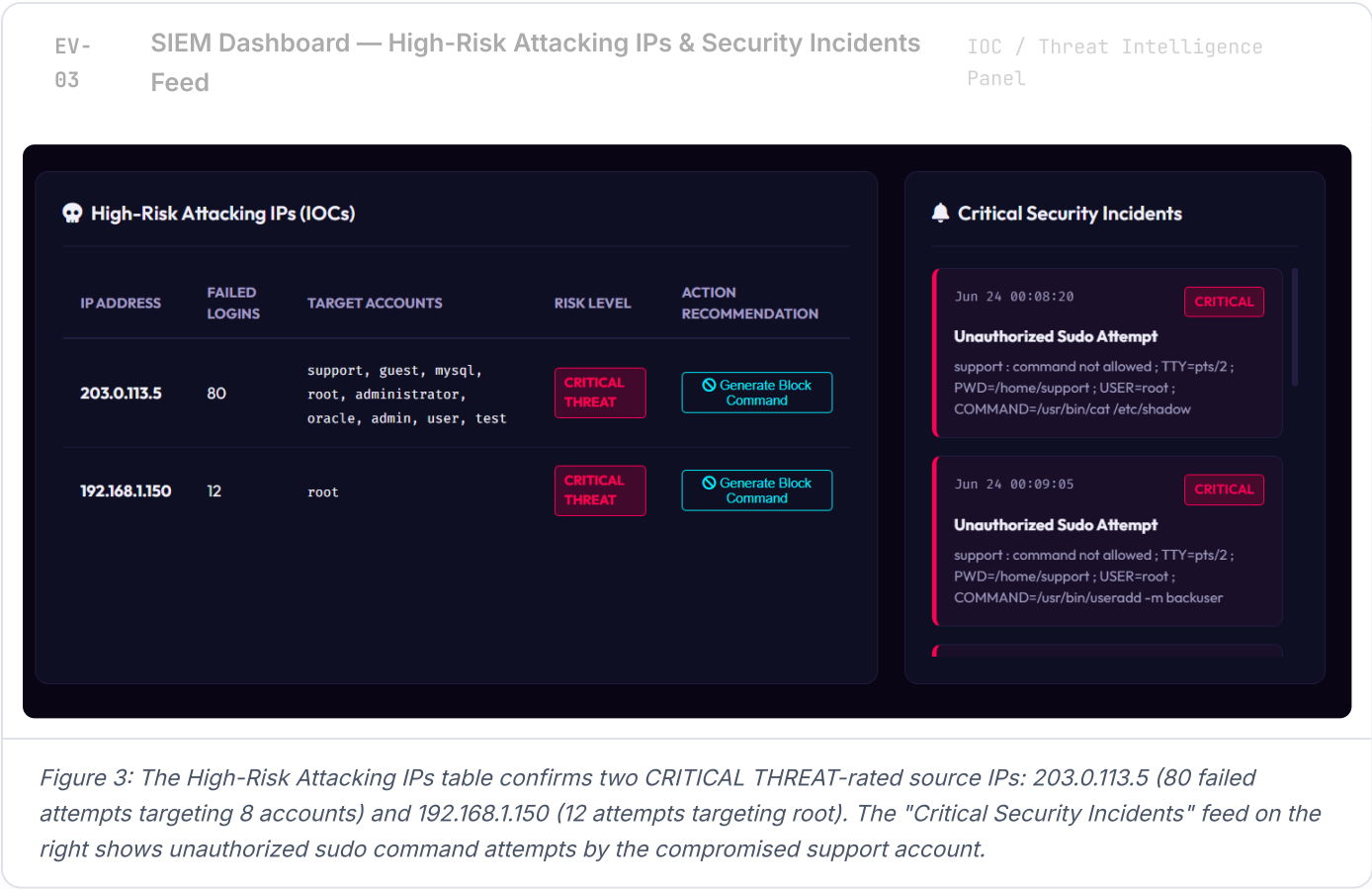


Figure 2: Aegis SIEM dashboard showing the login attempts timeline with a visible spike at 08:00 corresponding to the rapid brute-force attack, the authentication success ratio doughnut chart (92% failed vs. 8% successful), and the 8 detected security incidents counter.



The affected server must be isolated from the network immediately. The backdoor account must be removed and the compromised account disabled before any further system access is permitted.



Immediate Containment

Priority: Critical | Timeline: Now

- Disconnect debian-server from the network to stop active C2 communication
- Remove backdoor account: `userdel -r backuser`
- Disable and lock the compromised 'support' account: `usermod -L support`
- Kill all active sessions: `kill -KILL -u support`



Network Hardening

Priority: High | Timeline: 24h

- Block 203.0.113.5 at the perimeter firewall immediately
- Investigate internal device 192.168.1.150 for worm or malware activity
- Enable geo-IP blocking to restrict SSH to known regions only
- Configure connection-rate limits on the SSH port at firewall level



SSH Configuration Hardening

Priority: High | Timeline: 48h

- Set `PermitRootLogin no` in `/etc/ssh/sshd_config`
- Set `PasswordAuthentication no` — enforce SSH key-based login only
- Relocate SSH to a non-standard port (e.g. 22022)
- Restrict SSH access using `AllowUsers` directive



SIEM & Monitoring

Priority: Medium | Timeline: 1 week

- Deploy and configure **Fail2ban** to auto-ban IPs after 5 failures
- Create SIEM alert for any `sudo /bin/bash` shell spawns
- Set alerts for `useradd` and `usermod` root-level events
- Enable real-time log forwarding to centralized SIEM platform

7

Analyst Conclusion

Summary findings and investigation sign-off

This investigation confirms a **complete multi-stage attack** was carried out against `debian-server`, progressing from initial reconnaissance through to full root compromise and persistent backdoor installation. The attack is consistent with automated credential-stuffing toolkits commonly used by opportunistic threat actors targeting internet-exposed Linux SSH services.

The primary failure points identified were: (1) the presence of weak or reused passwords on system accounts, (2) the absence of SSH rate-limiting or brute-force protection, and (3) an overly permissive `sudoers` configuration that allowed the attacker to spawn a root shell. Immediate remediation of all findings in Section 6 is strongly advised to restore system integrity.

Prepared & Reviewed by
SOC Analyst — Tier 2
Aegis Cybersecurity — Threat Intelligence
June 21, 2026

